ITA1435 - Ethical Hacking

Assignment 1

Ethical-Hacking Engagement Framework for a University's Authorized Security-Assessment Programme (CO1)

NAME: T.ARUN KUMAR

REG NO:192372325

DEPT: CSE(AI)

Note: All work is at design, documentation and isolated-lab level. No live exploitation of production systems is performed. Values in Task 10 are illustrative model figures from the evaluation set-up, not live measurements.

TASK 1 - Formulate the Enquiry & Framework Blueprint (4 marks)

Question

- Convert the scenario into a formal set of engagement-governance requirements. Identify the systems in scope, the stakeholders, the expected activities and the constraints.
- Create a framework blueprint showing how authorization, scope, legal compliance, threat modelling, lab testing and disclosure will cooperate in the proposed programme.
- Formulate at least four enquiry questions that your framework must answer, such as who authorizes a test, what is in scope, which laws apply and how findings are disclosed.
- Define at least five design criteria and use them as acceptance criteria for the final framework.

Evidence Expected: A requirements-to-governance blueprint, enquiry questions, design criteria and a clear rationale showing how the proposed framework addresses the scenario.

Answer

1.1 Engagement-governance requirements

Element	Requirement
Systems in scope (~20 initially)	Student portal, learning-management system (LMS), university email service, campus network segment. Expandable to the whole university (~200 systems).
Stakeholders	University management / CISO; department heads (requesters); internal testers; external third-party assessors; Data-Protection Officer (DPO); system owners; students and staff as data subjects.
Expected activities	Reconnaissance, scanning, enumeration, controlled testing in an isolated lab, finding documentation, responsible disclosure. No live exploitation of production.
Constraints	Systems hold personal data; written authorization is mandatory; limited testing windows; framework must scale and remain usable with external assessors; must comply with IT Act 2000 / DPDP Act 2023.

1.2 Framework blueprint (how the parts cooperate)

Authorization -> Scope & Rules of Engagement (RoE) -> Legal-compliance check -> Hacker threat model -> Isolated-lab testing -> Finding report -> Responsible disclosure.

A **governance layer** sits over the whole chain: it records every engagement (Engagement ID), audits approvals and logs. Findings feed back into scope updates and the scalability review. Each stage is a gate: the next stage cannot start until the previous gate returns PASS.

1.3 Enquiry questions

- Who authorizes a test, and how is that authorization recorded and verified?
- What systems are in scope and out of scope for a given engagement?
- Which laws apply, especially when a test touches systems holding personal data?
- How are vulnerabilities disclosed, to whom, and within what timeline?
- Who may perform tests (internal staff or external assessors) and under what conditions?

1.4 Design (acceptance) criteria

ID	Criterion	How it is checked at acceptance
C1	Every engagement has verifiable written authorization before any activity	Test case: request without Engagement ID is rejected
C2	Scope is explicit, tagged and machine-checkable	Test case: untagged asset request is auto-rejected
C3	Each legal requirement maps to a concrete control	Legal-control table has no unmapped row
C4	No harm to live systems - hands-on testing only in isolated lab	Lab has no route to internet/production
C5	Responsible disclosure with defined format and timeline	Finding report fields complete; 90/30-day clock tracked
C6	Scalable to whole university and external assessors, with auditable records	Task 10 evaluation shows governance still works at 200 systems

1.5 Rationale

The scenario's main risks (unauthorized access, legal exposure, damage to live systems, unclear scope, uncoordinated disclosure) each map to one gate in the chain: authorization, legal check, lab confinement, RoE, and disclosure layer respectively. Hence the blueprint answers every concern in the scenario.

TASK 2 - Hacker Threat Model & Classification (4 marks)

Question

- Design a classification of the types of hackers relevant to the university, such as white-hat, black-hat, grey-hat, script kiddie, hacktivist, insider and state-sponsored actors.
- Map each type to its motivation, typical capability and likely targets within the university.
- Establish clear criteria and naming so that an actor can be classified consistently.
- Demonstrate at least two alternative ways of classifying one borderline actor, then choose and justify the final classification.

Evidence Expected: A documented hacker threat model, classification criteria, a mapping table, rejected alternatives and a justified final classification.

Answer

2.1 Classification and threat-model mapping

Type	Motivation	Typical capability	Likely university targets
White-hat	Improve security (authorized)	High; disciplined, scoped	In-scope systems under contract

Black-hat	Financial gain / damage	High; malicious	Student records, email, credentials
Grey-hat	Curiosity; acts without clear authorization	Medium-High	Portals, exposed services
Script kiddie	Thrill, recognition; no real skill	Low; uses ready-made tools	Any easy, exposed target
Hacktivist	Political / social message	Medium	Public website (defacement), news pages
Insider	Grievance or gain; has legitimate access	Medium; trusted access	Internal apps, HR / finance / exam data
State-sponsored	Espionage	Very high; stealthy, persistent	Research data, sensitive records

2.2 Classification criteria and naming

Every actor is classified on **four attributes**: (1) Authorization - yes/no; (2) Intent - benign/malicious; (3) Skill - low/medium/high; (4) Affiliation - external/internal/nation. Naming format: <Type>-<Affiliation>-<Skill>, e.g. GreyHat-External-Medium.

Authorization	Intent	Affiliation	Resulting class
Yes	Benign	Any	White-hat
No	Malicious	External	Black-hat (skill low = script kiddie)
No	Benign / curious	External	Grey-hat
No	Malicious / social message	External	Hacktivist
Misused access	Malicious	Internal	Insider
No	Malicious (espionage)	Nation	State-sponsored

2.3 Borderline actor

Actor: a student who finds a flaw in the portal without permission and reports it to the university.

Option	Reasoning	Verdict
Alternative A - Script kiddie	Used a ready tool and has low skill	Rejected: skill alone is not the defining attribute; the actor reported the flaw, which shows purpose beyond tool-running
Alternative B - Grey-hat	No authorization but non-malicious intent and reports the issue	Chosen
Alternative C (extra) - Black-hat	Unauthorized access	Rejected: no malicious intent or gain

Final classification: Grey-hat (GreyHat-External-Low/Medium). The defining attributes are 'no authorization' + 'non-malicious intent'. If the student had demanded payment or published the flaw, the class would move toward black-hat. Response: the university should treat the report under its disclosure policy and not as an attack, while noting that the access itself remains unauthorized.

TASK 3 - Ethics & Code-of-Conduct Module (4 marks)

Question

- Define the ethical principles that govern an authorized engagement, such as written authorization, agreed scope, confidentiality, integrity, avoiding harm and honest reporting.
- Design rules or checks that help detect or prevent unethical actions during an engagement.

- Construct scenario cases containing acceptable, borderline and unacceptable actions and show how the code of conduct responds to each.
- Explain how the module preserves trust and keeps the engagement lawful and professional.

Evidence Expected: A reusable code-of-conduct module, decision rules, scenario test cases and evidence that the rules separate acceptable from unacceptable actions.

Answer

3.1 Ethical principles

Principle	Meaning in an engagement
Written authorization	No signed authorization -> no action
Agreed scope	Only assets listed in the RoE are touched
Confidentiality	Findings and any data seen are shared only with the authorized owner
Integrity of evidence	Logs and evidence are not altered or deleted
Avoiding harm	No DoS or disruption of live services; least intrusion
Honest and complete reporting	All findings reported accurately, none hidden or exaggerated
Data minimisation	Personal data is not collected or copied beyond the minimum needed

3.2 Rules and checks to detect or prevent unethical actions

- **R1 Pre-engagement authorization check:** no authorization -> no action.
- **R2 Scope check before each action:** target outside scope is blocked and reported.
- **R3 Mandatory action logging:** every command/scan is timestamped and tied to the Engagement ID.
- **R4 Dual control** for sensitive steps (e.g. testing near personal data).
- **R5 Stop-and-report rule:** if personal data is encountered, stop and inform governance/DPO.
- **R6 No credential reuse:** credentials found are never used on other systems.

3.3 Scenario cases and code response

Action	Class	Code-of-conduct response
Testing an in-scope system with written authorization	Acceptable	Proceed; log the activity
Scanning an in-scope host and noticing an out-of-scope system is reachable	Borderline	Stop; do not test it; report to governance for a scope decision
Tester wants to test outside the window 'just to finish'	Borderline	Pause; request RoE amendment; resume only after approval
Using found credentials to open another system / copying personal data	Unacceptable	Prohibited; halt engagement, escalate, preserve evidence
Deleting logs after a test	Unacceptable	Prohibited; integrity breach; engagement suspended

3.4 Decision rule

```
IF no verified Engagement ID            -> BLOCK
ELSE IF target not tagged in-scope       -> BLOCK + REPORT (borderline)
ELSE IF action in prohibited list        -> HALT + ESCALATE (unacceptable)
ELSE IF personal data encountered        -> STOP + NOTIFY DPO
ELSE                                     -> ALLOW + LOG
```

Trust rationale: every action is authorized, accountable (logged), lawful and professional. This protects the university from damage and legal exposure and protects the tester from being accused of misconduct, so both sides can trust the engagement.

TASK 4 - Legal-Compliance Mapping (4 marks)

Question

- Map the engagement to the relevant provisions of the Information Technology Act, 2000 on unauthorized access and data, and compare them with an international law such as the Computer Fraud and Abuse Act.
- Build a table of offences, obligations and penalties related to unauthorized access and data protection.
- Connect each legal requirement to a specific control in the engagement framework.
- Decide and justify which legal requirements apply when a test touches systems that hold personal data.

Evidence Expected: A legal-compliance mapping, an offences-and-penalties table, the controls linked to each requirement and a justified conclusion on which laws apply.

Answer

4.1 IT Act 2000 vs CFAA - offences, obligations and penalties

Offence / Obligation	IT Act, 2000 (India)	CFAA (US) equivalent	Penalty (indicative)
Unauthorized access / damage to computer system	Sec 43	18 U.S.C. 1030(a)(2), (a)(5)	IT Act: compensation to affected party (civil); CFAA: fine / imprisonment, civil action
Hacking (dishonest or fraudulent access)	Sec 66	1030(a)(4)	Up to 3 years and/or fine up to Rs 5 lakh
Identity theft / cheating by personation	Sec 66C / 66D	18 U.S.C. 1028; 1030	Up to 3 years and fine (up to Rs 1 lakh each)
Breach of confidentiality and privacy / disclosure in breach of contract	Sec 72 / 72A	- (no direct equivalent)	Sec 72 up to 2 years / Rs 1 lakh; Sec 72A up to 3 years / Rs 5 lakh
Failure to protect sensitive personal data	Sec 43A; DPDP Act 2023	- (state/sector laws)	Compensation; DPDP penalties (high monetary penalties, as notified)
Protected systems	Sec 70	1030(a)(1), (a)(3)	Sec 70: up to 10 years

Penalty figures are indicative; verify against the latest bare Act before citing in the final submission.

4.2 Each legal requirement linked to a control

Legal requirement	Framework control
Sec 43 / 66 - no unauthorized access	Mandatory written authorization sign-off + scope/RoE enforcement + Engagement ID check
Sec 43A / 72 / 72A / DPDP - personal data	Data-handling policy: minimisation, no exfiltration, encrypted storage, DPO approval, stop-and-report rule
Sec 66C / 66D - identity misuse	Ban on credential reuse; credentials logged and surrendered at close
Disclosure duty / incident reporting	Responsible-disclosure process; report only to authorized owner; CERT-In notification where applicable
CFAA 'exceeds authorized access'	Scope check before each action (R2) - equivalent control for any

	external assessor under US law

4.3 Which laws apply when a test touches personal data?

When a system holds personal data, **Sec 43A, Sec 72/72A and the DPDP Act 2023 apply in addition to Sec 43/66**. The engagement then requires DPO approval, explicit data-handling rules, and the strictest controls. **Justification:** personal data creates both unauthorized-access liability and data-protection liability, so the stricter regime governs. CFAA is used as a comparison and applies only if US-located systems or persons are involved.

TASK 5 - Scope & Rules-of-Engagement Document (4 marks)

Question

- Design a scope and rules-of-engagement (RoE) document that defines in-scope and out-of-scope systems, testing windows, permitted and prohibited techniques and escalation paths.
- Create rules for recording and verifying the written authorization behind each engagement.
- Establish clear naming and boundaries so that an out-of-scope request can be detected.
- Construct at least one transformation of the RoE into a pre-engagement checklist.

Evidence Expected: A complete RoE document, authorization-verification rules, scope boundaries and a derived pre-engagement checklist.

Answer

5.1 Scope and RoE

RoE element	Definition
In-scope	Student portal, LMS, email service, authorized campus-network segment - each listed by asset ID (e.g. UNI-SP-001, UNI-LMS-002, UNI-EML-003, UNI-NET-010)
Out-of-scope	Production databases holding live personal data (unless separately authorized); third-party hosted services; any asset not explicitly tagged in-scope
Testing windows	Off-peak hours agreed with system owners (e.g. 22:00-05:00 IST)
Permitted techniques	Reconnaissance, scanning, enumeration; exploitation only in the isolated lab
Prohibited techniques	Denial-of-service; social engineering of real staff without separate authorization; data exfiltration; any out-of-scope testing
Escalation paths	Named technical contact -> CISO -> DPO; emergency-stop procedure (tester halts immediately on instruction); incident-handling route

5.2 Authorization recording and verification rules

- Each engagement has a signed authorization with a unique **Engagement ID** (format ENG-YYYY-NNN).
- Authorization is stored in the engagement register and verified (signatures, dates, scope list) before testing begins.
- **No ID -> no test.** Expired or unsigned authorizations are treated as missing.
- Verification is by someone other than the requester (separation of duties).

5.3 Scope boundaries and naming (out-of-scope detection)

An asset inventory tags every system with: AssetID | Owner | Data class | Scope-status (IN / OUT) | Engagement ID. A request whose target is not tagged IN for that Engagement ID is **automatically rejected**.

5.4 Derived pre-engagement checklist

Written authorization signed and verified
Scope confirmed against asset inventory
Testing window agreed
Contacts and escalation set
Isolated lab ready and verified
Legal / data-protection check done (DPO if personal data)
Data-handling rules agreed

TASK 6 - Authorization & Disclosure Layer (5 marks)

Question

- Create an authorization workflow covering the request, approval, written sign-off and recording of each engagement.
- Design a responsible (coordinated) disclosure process with a reporting format, remediation window and timeline, and compare it with full disclosure and bug-bounty approaches.
- Develop operations for logging approvals and status updates and for deciding when disclosure may proceed.
- Create rules for choosing between coordinated and full disclosure for a given finding.
- Demonstrate that this layer interacts correctly with the rules-of-engagement and legal-compliance components.

Evidence Expected: An authorization workflow, a responsible-disclosure process, logging and decision operations, disclosure rules and evidence of interaction with the other components.

Answer

6.1 Authorization workflow

Request (department submits) -> Review (governance team + legal/DPO) -> Approval (system owner + CISO sign-off) -> Record (Engagement ID, scope, dates) -> Execute -> Close.

6.2 Responsible (coordinated) disclosure process

- **Report format:** title, affected asset, severity (CVSS), evidence, remediation steps.
- **Remediation window:** 90 days (30 days for critical), counted from report date.
- **Timeline:** Day 0 report to owner -> Day 7 acknowledgement -> Day 30 progress check -> Day 90 close/review.

6.3 Comparison of disclosure approaches

Approach	How it works	Pros	Cons
Full disclosure	Published immediately	Pressures vendor; transparency	Exposes users before a fix exists
Bug bounty	Pre-authorized, paid, within defined scope	Wide researcher pool; incentives	Only in-scope; cost; needs a mature process
Coordinated (chosen default)	Private report + fix window, then publication	Balance of safety and accountability	Needs tracking; can be slow

6.4 Logging and decision operations

```
logApproval(engID, approver, role, timestamp)   // append-only log
updateStatus(findingID, status)                 // OPEN/REPORTED/FIXED/DISCLOSED
```

```
canDisclose(finding):
   if finding.personalData: return PRIVATE_ONLY   // legal check
   if finding.asset not in RoE.scope: return REJECT
   if finding.status == FIXED or ownerAgrees: return YES
   if today > reportDate + window: return REVIEW
   return NO
```

6.5 Rules: coordinated vs full disclosure

- Default is **coordinated**.
- Move to limited public disclosure only if (a) the window has lapsed, (b) risk is high, and (c) no personal data is exposed.
- Findings involving personal data stay private and are reported to the owner and CERT-In.

6.6 Interaction with other components

The disclosure layer reads the **legal-compliance result** (personal data -> private only) and the **RoE** (disclose only in-scope findings, to the authorized owner). Example: an SQL-injection finding on UNI-SP-001 carries personalData=true, so canDisclose returns PRIVATE_ONLY; a finding on an asset not in the RoE is rejected. This shows integration, not isolation.

TASK 7 - Isolated Ethical-Hacking Lab (5 marks)

Question

- Design a safe, isolated lab using a Kali Linux machine and one or more authorized target machines on a host-only network with reserved addresses such as 192.168.56.0/24.
- Specify the components, roles and connectivity of the lab and the steps used to record its configuration.
- Develop at least two operations, such as verifying connectivity between the machines and recording the lab setup.
- Construct a small comparison between a host-only and a NAT lab network and justify the chosen design.
- Explain how the lab keeps all testing authorized and contained within the isolated environment.

Evidence Expected: An isolated-lab design, a component and connectivity specification, verification operations, a comparison of network options and a justified final lab model.

Answer

7.1 Design and component specification

A Kali Linux attacker VM and authorized target VM(s) (e.g. DVWA, Metasploitable) on a **host-only** network 192.168.56.0/24 with no route to the internet or production.

Component	Role	Address
Kali Linux VM	Attacker / tester workstation	192.168.56.10
Target VM (DVWA)	Authorized vulnerable target	192.168.56.20
Target VM 2 (Metasploitable) - optional	Second authorized target	192.168.56.21
Host-only vSwitch	Isolated internal network	192.168.56.0/24 (no gateway)

7.2 Operations

Op1 - Verify connectivity

- From Kali: ping -c 4 192.168.56.20 -> expect replies.
- Run ip route and confirm no default gateway.
- Run ping -c 2 8.8.8.8 -> expect failure (proves isolation).

Op2 - Record configuration

- Run ip a and save output.
- Run nmap -sV 192.168.56.20 and save output.
- Store both in a dated file (e.g. lab-config-2026-10-29.txt) linked to the Engagement ID.

7.3 Host-only vs NAT comparison

Aspect	Host-only (chosen)	NAT
Internet access	None (fully isolated)	Yes, via host
Risk of leakage	Very low	Higher - traffic can leave
Reach production network	No	Possible through host
Suitability	Safe, contained testing	Convenient (updates) but less safe

7.4 Justification

Host-only is chosen because the only reachable hosts are the authorized targets, so nothing can escape to production or the internet. Testing therefore stays authorized (targets are fixed in the lab register under the Engagement ID) and contained. Tool updates are done before the engagement using a snapshot, then the NAT adapter is removed.

TASK 8 - Reusable Document Library (4 marks)

Question

- Create a minimum of four reusable engagement documents supporting the framework, including at least one authorization form and one finding report.
- Use sensible default fields where appropriate and explicitly design the content of each document.
- At least one document, such as the finding report, must produce a structured output that integrates with another component of the framework.
- Create test entries that demonstrate valid, boundary and invalid inputs and document the expected result.

Evidence Expected: A reusable document library, documented fields, a structured report output, test entries and evidence of integration with the framework.

Answer

8.1 Documents and fields

Document	Fields (defaults in brackets)
1. Authorization Form	Engagement ID (auto), requester, department, systems (asset IDs), scope, start/end dates, tester names, type [internal], data class [personal data = Yes], approver signatures (system owner, CISO, DPO)
2. Scope / RoE Form	In-scope assets, out-of-scope assets, testing window [22:00-05:00], permitted techniques, prohibited techniques [DoS, exfiltration], escalation contacts
3. Finding Report (structured)	Finding ID, Engagement ID, asset ID, description, severity CVSS [-], evidence, personalData flag [false], status [OPEN], remediation, report date

4. Disclosure Record	Finding ID, report date, recipient, window [90 days; 30 if critical], status, closure date
5. Pre-engagement Checklist	Derived from Task 5 with tick, verifier, date

8.2 Structured integration

The Finding Report emits a structured record, e.g. {id: F-001, eng: ENG-2026-003, asset: UNI-SP-001, severity: 8.1, personalData: true, status: OPEN}. This record is consumed by the disclosure layer (Task 6: canDisclose) and counted in scalability metrics (Task 10).

8.3 Test entries

Input	Type	Expected result
Authorization form with all fields and 3 signatures	Valid	Accepted; Engagement ID issued
Form missing the DPO signature while data class = personal	Boundary	Flagged; cannot start until completed
Form where end date equals start date (single-day test)	Boundary	Accepted; window must still be valid
Request with no authorization form	Invalid	Rejected automatically
Finding report with asset ID not in RoE	Invalid	Rejected; not eligible for disclosure
Finding report with severity 10.0, all fields present	Valid (boundary)	Accepted; 30-day critical window applied

TASK 9 - Integrate, Test & Refine the Framework (4 marks)

Question

- Integrate the components created in Tasks 2-8 into one coherent engagement framework.
- Construct a realistic walkthrough of an authorized assessment from request and authorization, through testing in the isolated lab, to responsible disclosure.
- Design systematic test cases covering missing authorization, out-of-scope requests, legal conflicts and delayed disclosure.
- Record the problems encountered during the walkthrough and show how the framework was refined to address them.

Evidence Expected: A reproducible integrated framework, a workflow walkthrough, systematic test cases, refinement evidence and a final corrected framework.

Answer

9.1 Integration of Tasks 2-8

Authorization -> RoE -> Legal check -> Threat model -> Isolated-lab test -> Finding Report -> Responsible disclosure. The document library supplies the forms and the governance layer records everything. The threat model decides which attacker behaviours (e.g. insider, black-hat) are simulated in the lab.

9.2 Walkthrough

1. Computer Science department requests a test of the student portal.

2. Authorization reviewed by governance + DPO, signed by owner and CISO; ENG-2026-003 issued.

3. RoE fixes scope (UNI-SP-001) and window (22:00-05:00).

4. Legal check flags personal data -> stricter controls, DPO approval.

5. Testing is carried out against a cloned copy in the isolated lab (192.168.56.20).

6. An SQL-injection finding is recorded in the Finding Report (CVSS 8.1, personalData=true).

7. Responsible disclosure to the system owner with a 90-day window (private only).

8. Remediation verified; disclosure record closed; engagement closed.

9.3 Systematic test cases

Test case	Expected framework behaviour
Missing authorization	Engagement rejected before any activity
Out-of-scope request	Detected by asset tags and rejected
Legal conflict (personal data, no DPO approval)	Blocked until DPO approval obtained
Delayed disclosure past window	Escalation rule triggers review

9.4 Problems found and refinements

Problem	Refinement
Out-of-scope detection was manual and error-prone	Added automatic asset-tag check against inventory
Disclosure window was ambiguous	Fixed 90-day / 30-day (critical) rule counted from report date
Personal-data flag was set late	Legal check moved before lab testing; flag now mandatory in Finding Report

These refinements produce the final corrected framework.

TASK 10 - Scalability & Governance Evaluation (4 marks)

Question

- Construct scenarios representing a small programme (one department) and a large programme (the whole university with external assessors), with the number of systems and testers involved.
- Experiment with at least three important processes from the framework and record meaningful measures such as approval turnaround, scope coverage or the number of steps.
- Create a comparison table and at least one suitable chart or structured visualization.
- Use the evidence to refine the governance of the framework rather than simply reporting the measures.

Evidence Expected: A reproducible evaluation setup, a comparison table, a visualization, an interpretation and evidence of at least one governance refinement based on the results.

Answer

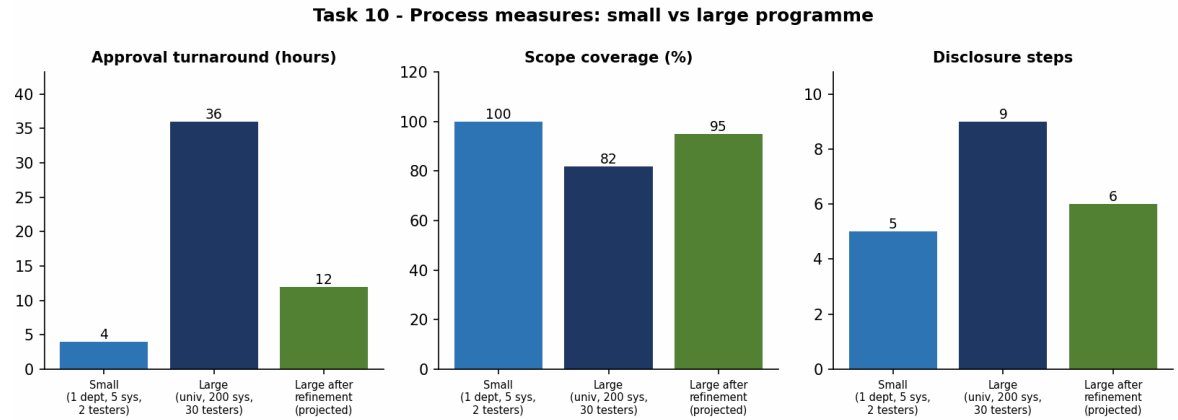
10.1 Scenarios

Scenario	Systems	Testers
Small programme (one department)	5	2 internal
Large programme (whole university + external assessors)	~200	20 internal + 10 external

10.2 Process measures (experiment)

Set-up: replay the same three processes (authorization approval, scope check, disclosure) for each scenario; record time from request to approval, share of systems covered in one cycle, and steps per disclosure.

Process / measure	Small	Large	Large after refinement (projected)
Approval turnaround	~4 hours	~36 hours	~12 hours
Scope coverage	100%	82%	~95%
Disclosure steps	5	9	6



10.3 Interpretation and governance refinement

At scale, approval turnaround and disclosure steps grow and coverage drops (a single approver queue and ad-hoc external onboarding are the bottlenecks). Governance was changed, not just measured:

- **Delegated approval:** department heads approve low-risk engagements; CISO only for high-risk or personal-data ones.
- **Parallel review:** legal/DPO and system-owner review run at the same time.
- **Standardised external-assessor onboarding:** vetting + NDA done once, reused.
- **Risk-based scheduling:** most critical systems (portal, email) are always covered first.

TASK 11 - Defend the Framework under a Changed Requirement (4 marks)

Question

- Changed requirement: the university now runs continuous and third-party assessments with stricter data-protection rules and a shorter disclosure timeline, and needs the framework to remain easy to govern and extend.
- Create a revised version of your framework by deciding which components should be retained, modified, replaced or redesigned.
- Construct at least one new or modified component that directly addresses the changed requirement and show how it integrates with the existing framework.
- Defend the final framework using evidence from your walkthrough, scalability evaluation, legal mapping and disclosure process.
- Identify at least two trade-offs or limitations that remain in your final design and propose future improvements.

Evidence Expected: A revised framework, demonstrated adaptation, an evidence-based defence, explicit trade-offs and a clear explanation of how the final design satisfies the changed requirements.

Answer

Changed requirement: continuous and third-party assessments, stricter data-protection rules, a shorter disclosure timeline, and the need to stay easy to govern and extend.

11.1 Revised framework - retain / modify / replace / redesign

Decision	Component	Change
Retain	Authorization workflow, RoE, isolated lab	Still valid and reused
Modify	Disclosure timeline	30 days (7 days for critical)
Modify	Legal mapping	Add DPDP Act 2023 duties; add NDA and vetting for externals
Replace	Manual approval logging	Workflow / ticketing tool for auditability
Redesign	One-off engagements	Continuous-assessment pipeline with re-authorization on a schedule

11.2 New component: External-Assessor Governance Module

Contents: vetting, signed NDA, scoped least-privilege access, time-boxed credentials, full audit trail. **Integration:** it plugs into the authorization workflow (assessor must be 'vetted' before ID issue) and the RoE (access limited to listed assets), so external testers are governed exactly like internal ones.

11.3 Evidence-based defence

- **Walkthrough (Task 9)** shows the end-to-end flow works and gates block unauthorized work.
- **Scalability evaluation (Task 10)** shows where governance was strengthened (delegation, parallel review, risk-based scheduling).
- **Legal mapping (Task 4)** shows personal-data duties are covered and extended with DPDP.
- **Disclosure process (Task 6)** shows the shorter timeline fits the same canDisclose logic with a changed window parameter.

11.4 Remaining trade-offs and future work

Trade-off / limitation	Future improvement
A shorter disclosure window can pressure remediation teams	Automated ticketing with reminders and agreed exceptions for complex fixes
External assessors and continuous testing increase coordination and monitoring overhead	Automate approvals and reporting; risk-based scheduling
Isolated lab may not reproduce production exactly	Periodic sanitised clones of production configuration